

1 · HTTP request

Authorization: Bearer <access token> · cuerpo validado con ValidationPipe (whitelist)

2 · JwtAuthGuard (guard global)

Verifica la firma/expiración del JWT (secreto de access). Adjunta AuthenticatedUser { id, empresaId, email, permisos }. @Public() exime login y refresh.

3 · PermisosGuard (guard global)

@RequierePermiso('anular_venta', ...) exige que el usuario tenga esos permisos. Autorización por permiso, nunca por nombre de rol.

4 · TenantInterceptor (interceptor global)

Lee req.user.empresaId y ejecuta el handler dentro de TenantContext.run(empresaId) — AsyncLocalStorage, propagado a todo lo async.

5 · Controller → Caso de uso

Orquesta los puertos del dominio. El dominio es puro (no importa Nest ni Prisma).

6 · PrismaService.db (extensión \$extends)

En cada query lee el empresaId del ALS: inyecta where empresaId en lecturas/updates/deletes y lo fija en creaciones. Sin contexto → fail-closed. withTenant() abre transacción con SET LOCAL app.current_empresa.

7 · PostgreSQL

Capa 1 = filtro Prisma automático (empresaId). Capa 2 = Row-Level Security por variable de sesión (F6). Un WHERE olvidado no puede cruzar datos entre negocios.